

第 1 篇

网络安全基础

第1章

引言

在计算机发明之前,人们主要靠物理手段(如保险柜)和行政手段(如制定相应的规章制度)来保证重要信息的安全。在第二次世界大战期间,人们发明了各种机械密码机,以保证军事通信的安全。虽然这些机械密码机在今天看来其安全性非常有限,但它们在第二次世界大战中战功卓著,其设计的精巧令人惊叹。第二次世界大战期间使用的各种机械密码机如图 1-1 所示。

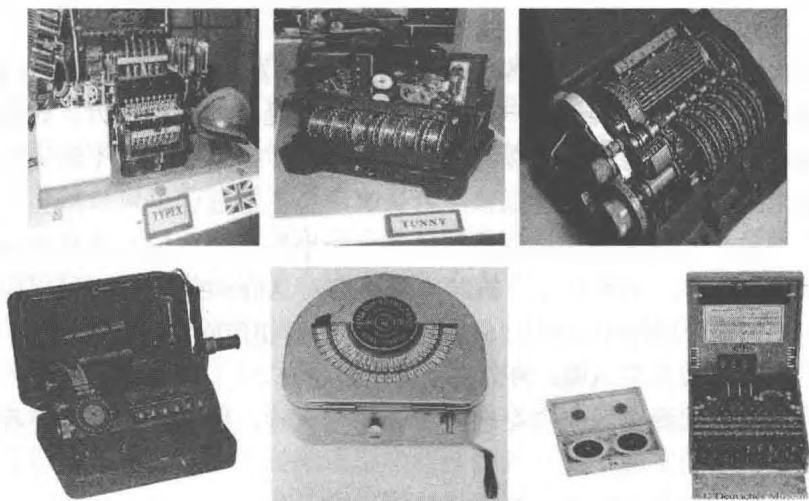


图 1-1 第二次世界大战期间使用的各种机械密码机

自 1946 年 2 月 14 日世界上第一台计算机 ENIAC 在美国宾夕法尼亚大学诞生以来,人们对信息安全的需求经历了两次重大的变革。计算机的发明给信息安全带来了第一次变革。计算机用户的许多重要文件和信息均存储于计算机中,因此对这些文件和信息安全保护成为一个重要的研究课题。人们迫切需要自动的加密工具对这些重要文件和机密数据进行加密,同时需要对这些文件设置访问控制权限,还需要保证数据免遭非法篡改。这一切均属于计算机安全的研究范畴。

计算机网络及分布式系统的出现给信息安全带来了第二次变革。人们通过各种通信网络进行数据的传输、交换、存储、共享和分布式计算。网络的出现给人们的生活带来了极大的便利,但同时也带来了极大的安全风险。在信息传输和交换时,需要对通信信道上传输的机密数据进行加密;在数据存储和共享时,需要对数据库进行安全的访问控制和对访问者授权;在进行多方计算时,需要保证各方机密信息不被泄漏。这些均属于网络安全的范畴。

实际上,上述两种形式的安全并没有明确的界限。目前,几乎所有的计算机均与

Internet 相连，计算机主机的安全会直接影响网络安全，网络安全也会直接导致计算机主机的安全问题。例如，对信息系统最常见的攻击就是计算机病毒，它可能最先感染计算机的磁盘和其他存储介质，然后加载到计算机系统中，并通过 Internet 传播。

本书主要讨论网络安全，涉及内容非常广泛，既包括计算机网络安全的问题，又包括通信网安全的问题。为了便于读者对本书所讨论的内容有比较感性的认识，下面先举几个与网络安全有关的例子。

(1) 用户 Alice 向用户 Bob 传送一个包含敏感信息（如工资单）的文件。出于安全考虑，Alice 将该文件加密。恶意的窃听者 Eve 可以利用数据嗅探软件在网络上截获该加密文件，并千方百计地对其解密以求获得该敏感信息。

(2) 网络管理员 Alice 向计算机 Bob 发送一条消息，命令计算机 Bob 更新权限控制文件以允许新用户可以访问计算机。攻击者 Eve 截获并修改该消息，并冒充管理员向计算机 Bob 发出修改访问权限的命令，而 Bob 误以为是管理员发来的消息并按照 Eve 的命令更新权限文件。

(3) 在网上进行电子交易时，客户 Alice 会将订单发给商家 Bob。Bob 接到订单后，会与客户的开户行联系，以确认客户的账户存在并有足够的支付能力。此后，商家将确认信息发给客户，并自动将货款划拨到商家的账户上。如果 Bob 是不法商家，他在收到货款后，会拒绝给客户发货，或者抵赖，否认客户曾经下过订单。

(4) 用户 Alice 购买了一部移动电话，在使用网络服务之前，她必须通过注册获得一个 SIM 卡或 UIM 卡。当她打开手机时，网络会对 Alice 的身份进行认证。如果 Alice 是一个不法用户，她可以使用盗取的 SIM/UIM 卡免费使用网络提供的服务；当然，如果基站是假冒的，它也会获取 Alice 的一些秘密个人信息。

虽然以上例子无法涵盖网络中存在的所有安全风险，但是这些例子使我们对网络安全的重要性有了初步的了解。

一般来说，信息安全有以下 3 个基本目标：

(1) 保密性 (confidentiality)。即确保信息不被泄漏或呈现给非授权的人。

(2) 完整性 (integrity)。即确保数据的一致性；特别要防止非授权地生成、修改或毁坏数据。

(3) 可用性 (availability)。即确保合法用户不会无缘无故地被拒绝访问信息或资源。在今天的网络环境下，还有一个基本的目标是不能被忽视的，它就是合法使用。

(4) 合法使用 (Legitimate Use)。确保资源不被非授权的人或以非授权的方式使用。

为了支持这些基本的安全目标，网络管理员需要有一个非常明确的安全策略，并且需要实施一系列的安全措施来确保安全策略所描述的安全目标能够得以实现。本书描述的两大类分别属于通信安全和计算机安全的范畴。通信安全是对通信过程中所传输的信息施加保护；计算机安全则是对计算机系统与信息施加保护，它包含操作系统安全和数据库安全两个子类。此外，还有一类属于网络安全的范畴，它包括网络边界安全、Web 安全及电子邮件安全等内容。通信安全、计算机安全和网络安全措施需要与其他类型的安全措施，诸如物理安全和人员安全措施配合使用，才能更有效地发挥作用。本章主要介绍如下一些基本的概念：

- 网络安全需求。
- 安全威胁与防护措施。
- 网络安全策略。
- 安全攻击的分类。
- 网络攻击的常见形式。
- 网络安全服务。
- 网络安全机制。
- 网络安全的一般模型。

在后面的章节中，将详细讨论网络安全实践中常用的理论和技术，并结合一些具体的网络应用，介绍一些网络安全产品和网络安全解决方案。

1.1

对网络安全的需求

在人们的日常生活及赖以生存的这个世界中，信息、信息资产及信息产品已经变得至关重要。加强网络安全的必要性可以从具体发生的安全事件中得到证明。公开报道的安全事件实际上只占很小的比例，事实上，人们不愿对所发生的安全事件进行宣扬，其原因有很多。在政府部门中，泄漏有关安全漏洞及系统脆弱性信息是受到严格控制的，与安全有关的信息也是严格保密的，因为一旦公布了这些信息，敌手就会利用这些信息来攻击其他类似的系统，从而给这些系统带来潜在的威胁。在商业市场中，人们不愿公开与安全有关的信息也是出于自身利益的考虑。例如，银行及其他金融机构都不愿公开承认他们的系统存在安全问题，因为公开其安全问题会使用户对银行在保护其财产方面的能力产生怀疑，从而将他们的资金或资产转移到其他金融机构或银行。造成这种对安全信息进行封锁的状况还受到来自法律和潜在损失等因素的影响。例如，若某个公司保存有许多用户的信息，公司要对这些信息的任何非授权泄漏承担法律责任。因此，一旦计算机系统受到入侵造成所保护信息泄漏，该公司不会公开承认信息的丢失。虽然政府部门和商业部门对本部门发生的安全事件的报道有着极其严格的限制，但是由于网络的广泛使用，要对发生安全事件的信息进行全面的保护与限制是不可能的。

1.1.1 网络安全发展态势

在今天的计算机技术产业中，网络安全是急需解决的最重要的问题之一。由美国律师联合会（American Bar Association）所做的一项与安全有关的调查发现，有40%的被调查者承认在他们的机构内曾经发生过计算机犯罪事件。在过去的几年里，Internet继续快速发展，Internet用户数量急剧攀升。随着网络基础设施的建设和Internet用户的激增，网络与信息安全问题越来越严重，因黑客事件而造成的损失也越来越巨大。

第一，计算机病毒层出不穷，肆虐全球，并且逐渐呈现新的传播态势和特点。其主要表现是传播速度快，与黑客技术结合在一起而形成的“混种病毒”和“变异病毒”越来越多。病毒能够自我复制，主动攻击与主动感染能力增强。当前，全球计算机病毒已

达 8 万多种，每天要产生 5~10 种新病毒。

第二，黑客对全球网络的恶意攻击势头逐年攀升。近年来，网络攻击还呈现出黑客技术与病毒传播相结合的趋势。2001 年以来，计算机病毒的大规模传播与破坏都同黑客技术的发展有关，二者的结合使病毒的传染力与破坏性倍增。这意味着网络安全遇到了新的挑战，即集病毒、木马、蠕虫和网络攻击为一体的威胁，可能造成快速、大规模的感染，造成主机或服务器瘫痪，数据信息丢失，损失不可估量。在网络和无线电通信普及的情况下，尤其是在计算机网络与无线通信融合、国家信息基础设施网络化的情况下，黑客加病毒的攻击很可能构成对网络生存与运行的致命威胁。如果黑客对国家信息基础设施中的任何一处目标发起攻击，都可能导致巨大的经济损失。

第三，由于技术和设计上的不完备，导致系统存在缺陷或安全漏洞。这些漏洞或缺陷主要存在于计算机操作系统与网络软件之中。例如，微软的 Windows XP 操作系统中含有数项严重的安全漏洞，黑客可以透过此漏洞实施网络窃取、销毁用户资料或擅自安装软件，乃至控制用户的整个计算机系统。正是因为计算机操作系统与网络软件难以完全克服这些漏洞和缺陷，使得病毒和黑客有了可乘之机。由于操作系统和应用软件所采用的技术越来越先进和复杂，因此带来的安全问题就越来越多。同时，由于黑客工具随手可得，使得网络安全问题越来越严重。所谓“网络是安全的”说法只是相对的，根本无法达到“绝对安全”的状态。

第四，世界各国军方都在加紧进行信息战的研究。近几年来，黑客技术已经不再局限于修改网页、删除数据等惯用的伎俩，而是堂而皇之地登上了信息战的舞台，成为信息作战的一种手段。信息战的威力之大，在某种程度上不亚于核武器。在海湾战争、科索沃战争及巴以战争中，信息战发挥了巨大的威力。

今天，“制信息权”已经成为衡量一个国家实力的重要标志之一。信息空间上的信息大战正在悄悄而积极地酝酿，小规模的信息战一直不断出现、发展和扩大。信息战是信息化社会发展的必然产物。在信息战场上能否取得控制权，是赢得政治、外交、军事和经济斗争胜利的先决条件。信息安全问题已成为影响社会稳定和国家安危的战略性问题。

1.1.2 敏感信息对安全的需求

与传统的邮政业务和有纸办公不同，现代的信息传递、存储与交换是通过电子和光子完成的。现代通信系统可以让人类实现面对面的电视会议或电话通信。然而，流过信息系统的信息有可能十分敏感，因为它们可能涉及产权信息、政府或企业的机密信息，或者与企业之间的竞争密切相关。目前，许多机构已经明确规定，对网络上传输的所有信息必须进行加密保护。从这个意义上讲，必须对数据保护、安全标准与策略的制定、安全措施的实际应用等各方面工作进行全面的规划和部署。

根据多级安全模型，通常将信息的密级由低到高划分为秘密级、机密级和绝密级，以确保每一密级的信息仅能让那些具有高于或等于该权限的人使用。所谓机密信息和绝密信息，是指国家政府对军事、经济、外交等领域严加控制的一类信息。军事机构和国家政府部门应特别重视对信息施加严格的保护，特别应对那些机密和绝密信息施加严格的保护措施。对于那些被认为敏感但非机密的信息，也需要通过法律手段和技术手段加

以保护,以防止信息泄漏或被恶意修改。事实上,一些政府部门的信息是非机密的,但它们通常属于敏感信息。一旦泄漏这些信息,有可能对社会的稳定造成危害。因此,不能通过未加保护的通信媒介传送此类信息,而应该在发送前或发送过程中对此类信息进行加密保护。当然,这些保护措施的实施是要付出代价的。除此之外,在系统的方案设计、系统管理和系统的维护方面还需要花费额外的时间和精力。近年来,一些采用极强防护措施的部门也面临着越来越严重的安全威胁。今天的信息系统不再是一个孤立的系统,通信网络已经将无数个独立的系统连接在一起。在这种情况下,网络安全也呈现出许多新的形式和特点。

1.1.3 网络应用对安全的需求

Internet 从诞生到现在只有短短几十年的时间,但其爆炸式的技术发展速度远远超过人类历史上任何一次技术革命。然而,从长远发展趋势来看,现在的 Internet 还处于发展的初级阶段,Internet 技术存在着巨大的发展空间和潜力。

随着网络技术的发展,网络视频会议、远程教育等各种新型网络多媒体应用不断出现,传统的网络体系结构越来越显示出局限性。1996年,美国政府制定了下一代 Internet (Next Generation Internet, NGI) 计划,与目前使用的 Internet 相比,它的传输速度将更快、规模更大,而且更安全。

1.2

安全威胁与防护措施

1.2.1 基本概念

所谓安全威胁,是指某个人、物、事件或概念对某一资源的保密性、完整性、可用性或合法使用所造成的危险。攻击就是某个安全威胁的具体实施。

所谓防护措施,是指保护资源免受威胁的一些物理的控制、机制、策略和过程。脆弱性是指在实施防护措施中或缺少防护措施时系统所具有的弱点。

所谓风险,是对某个已知的、可能引发某种成功攻击的脆弱性的代价的测度。当某个脆弱的资源的价值越高且成功攻击的概率越大时,风险就越高;反之,当某个脆弱资源的价值越低且成功攻击的概率越小时,风险就越低。风险分析能够提供定量的方法,以确定是否应保证在防护措施方面的资金投入。

安全威胁有时可以分为故意(如黑客渗透)和偶然(如信息被发往错误的地方)两类。故意的威胁又可以进一步分为被动攻击和主动攻击。被动攻击只对信息进行监听(如搭线窃听),而不对其进行修改。主动攻击却对信息进行故意的修改(如改动某次金融会话过程中货币的数量)。总之,被动攻击比主动攻击更容易以更少的花费付诸实施。

目前尚没有统一的方法来对各种威胁加以区别和进行分类,也难以理清各种威胁之间的相互关系。不同威胁的存在及其严重性随着环境的变化而变化。然而,为了解释网络安全服务的作用,我们将现代计算机网络及通信过程中常遇到的一些威胁汇编成图表,

如图 1-2 和表 1-1 所示。下面分 3 个阶段对威胁进行分析：①基本的威胁；②主要可实现威胁；③潜在威胁及分类。

1.2.2 安全威胁的来源

1. 基本威胁

下面 4 种基本安全威胁直接反映本章开篇时所划分的 4 个安全目标：

(1) **信息泄漏**：信息被泄漏或透露给某个非授权的人或实体。这种威胁来自诸如窃听、搭线或其他更加错综复杂的信息探测攻击。

(2) **完整性破坏**：数据的一致性通过非授权的增删、修改或破坏而受到损坏。

(3) **拒绝服务**：对信息或资源的访问被无条件地阻止。这可能由以下攻击所致：攻击者通过对系统进行非法的、根本无法成功的访问尝试使系统产生过量的负荷，从而导致系统的资源在合法用户看来是不可使用的。拒绝服务也可能是因为系统在物理上或逻辑上受到破坏而中断服务。

(4) **非法使用**：某一资源被某个非授权的人或以某种非授权的方式使用。例如，侵入某个计算机系统的攻击者会利用此系统作为盗用电信服务的基点，或者作为侵入其他系统的“桥头堡”。

2. 主要的可实现威胁

在安全威胁中，主要的可实现威胁应该引起高度关注，因为这类威胁一旦成功实施，就会直接导致其他任何威胁的实施。主要的可实现威胁包括渗入威胁和植入威胁。

主要的渗入威胁有如下几种：

(1) **假冒**。某个实体（人或系统）假装成另外一个不同的实体。这是突破某一安全防线最常用的方法。这个非授权的实体提示某个防线的守卫者，使其相信它是一个合法实体，此后便攫取了此合法用户的权利和特权。黑客大多采取这种假冒攻击方式来实施攻击。

(2) **旁路控制**。为了获得非授权的权利和特权，某个攻击者会发掘系统的缺陷和安全漏洞。例如，攻击者通过各种手段发现原本应保密但又暴露出来的一些系统“特征”。攻击者可以绕过防线守卫者侵入系统内部。

(3) **授权侵犯**。一个授权以特定目的使用某个系统或资源的人，却将其权限用于其他非授权的目的。这种攻击的发起者往往属于系统内的某个合法的用户，因此这种攻击又称为“内部攻击”。

主要的植入类型的威胁有如下几种：

(1) **特洛伊木马 (Trojan Horse)**。软件中含有一个不易觉察的或无害的程序段，当被执行时，它会破坏用户的安全性。例如，一个表面上具有合法目的的应用程序软件，如文本编辑软件，它还具有一个暗藏的目的，就是将用户的文件复制到一个隐藏的秘密文件中，这种应用程序就称为特洛伊木马。此后，植入特洛伊木马的那个攻击者就可以阅读到该用户的文件。

(2) **陷门 (Trapdoor)**。在某个系统或其部件中设置“机关”，使在提供特定的输入

数据时，允许违反安全策略。例如，如果在一个用户登录子系统上设有陷门，当攻击者输入一个特别的用户身份号时，就可以绕过通常的口令检测。

3. 潜在威胁

在某个特定的环境中，如果对任何一种基本威胁或主要的可实现的威胁进行分析，就能够发现某些特定的潜在威胁，而任意一种潜在的威胁都可能导致一些更基本的威胁发生。例如，在对信息泄漏这种基本威胁进行分析时，有可能找出以下几种潜在的威胁：

- (1) 窃听（Eavesdropping）。
- (2) 流量分析（Traffic Analysis）。
- (3) 操作人员的不慎所导致的信息泄漏。
- (4) 媒体废弃物所导致的信息泄漏。

图 1-2 列出了一些典型的威胁及它们之间的相互关系。注意，图中的路径可以交错。例如，假冒攻击可以成为所有基本威胁的基础，同时假冒攻击本身也存在信息泄漏的潜在威胁。信息泄漏可能暴露某个口令，而用此口令攻击者也可以实施假冒攻击。表 1-1 列出了各种威胁之间的差异，并分别进行了描述。

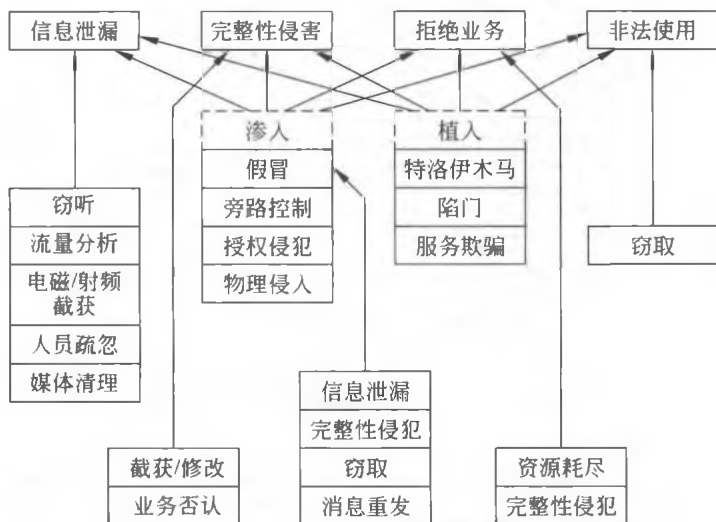


图 1-2 典型的威胁及其相互关系

对 3000 种以上的计算机误用案例所做的一次抽样调查显示，最主要的几种安全威胁如下（按照出现频率由高至低排列）：

- (1) 授权侵犯。
- (2) 假冒攻击。
- (3) 旁路控制。
- (4) 特洛伊木马或陷门。
- (5) 媒体废弃物。

在 Internet 中，网络蠕虫（Internet Worm）就是将旁路控制与假冒攻击结合起来的一种威胁。旁路控制就是利用已知的 UNIX，Windows 和 Linux 等操作系统的安全缺陷，

避开系统的访问控制措施，进入到系统内部。而假冒攻击则通过破译或窃取用户口令，冒充合法用户使用网络服务和资源。

表 1-1 典型的网络安全威胁

威 胁	描 述
授权侵犯	一个被授权以特定目的使用系统的人，却将此系统用于其他非授权的目的
旁路控制	攻击者发掘系统的安全缺陷或安全脆弱性，以绕过访问控制措施
拒绝服务*	对信息或其他资源的合法访问被无条件地拒绝
窃听攻击	信息从被监视的通信过程中泄漏出去
电磁/射频截获	信息从电子或机电设备所发出的无线频率或其他电磁场辐射中被提取出来
非法使用	资源被某个非授权的人或以非授权的方式使用
人员疏忽	一个被授权的人为了金钱等利益或由于粗心，将信息泄漏给非授权的人
信息泄漏	信息被泄漏或暴露给某个非授权的人
完整性侵犯*	数据的一致性由于非授权的增删、修改或破坏而受到损害
截获/修改*	某一通信数据在传输过程中被改变、删除或替换
假冒攻击*	一个实体（人或系统）假装成另一个不同的实体
媒体废弃物	信息从被废弃的磁带或打印的废纸中泄漏出去
物理入侵	入侵者通过绕过物理控制（如防盗门）而获得对系统的访问
消息重发*	对所截获的某次合法通信数据备份，出于非法的目的而重新发送该数据
业务否认*	参与某次通信交换的一方，事后错误地否认曾经发生过此次信息交换
资源耗尽	某一资源（如访问接口）被故意地超负荷使用，导致其他用户服务中断
服务欺骗	某一伪造的系统或部件欺骗合法的用户或系统，自愿放弃敏感的信息
窃取	某一安全攸关的物品被盗，例如令牌或身份卡
流量分析*	通过对通信流量的模式进行观察，机密信息有可能泄漏给非授权的实体
陷门	将某一“特征”嵌入某个系统或其部件中，当输入特定数据时，允许违反安全策略
特洛伊木马	一个不易察觉或无害程序段的软件，当其被运行时，就会破坏用户的安全性

说明：带*的威胁表示在计算机通信安全中可能发生的威胁。

1.2.3 安全防护措施

在安全领域中，存在多种类型的防护措施。除了采用密码技术的防护措施外，还有其他类型的安全防护措施：

（1）物理安全。包括门锁或其他物理访问控制措施、敏感设备的防篡改和环境控制等。

（2）人员安全。包括对工作岗位敏感性的划分、雇员的筛选，同时也包括对人员的安全性培训，以增强其安全意识。

（3）管理安全。包括对进口软件和硬件设备的控制，负责调查安全泄漏事件，对犯罪分子进行审计跟踪，并追查安全责任。

(4) 媒体安全。包括对受保护的信息进行存储, 控制敏感信息的记录、再生和销毁, 确保废弃的纸张或含有敏感信息的磁性介质被安全销毁。同时, 对所用媒体进行扫描, 以便发现病毒。

(5) 辐射安全。对射频 (RF) 及其他电磁 (EM) 辐射进行控制 (又称 TEMPEST 保护)。

(6) 生命周期控制。包括对可信系统进行系统设计、工程实施、安全评估及提供担保, 并对程序的设计标准和日志记录进行控制。

一个安全系统的强度与其最弱链路的强度相同。为了提供有效的安全性, 需要将不同种类的威胁对抗措施联合起来使用。例如, 当用户将口令遗忘在某个不安全的地方或受到欺骗而将口令暴露给某个未知的电话用户时, 即使技术上是完备的, 用于对付假冒攻击的口令系统也将无效。

防护措施可用来对付大多数安全威胁, 但是采用每种防护措施均要付出代价。网络用户需要认真考虑这样一个问题: 为了防止某个攻击所付出的代价是否值得。例如, 在商业网络中, 一般不考虑对付电磁 (EM) 或射频 (RF) 泄漏, 因为它们对商用环境来说风险很小, 而且其防护措施又十分昂贵。但在机密环境中, 我们会得出不同的结论。对于某一特定的网络环境, 究竟采用什么安全防护措施, 这种决策属于风险管理的范畴。目前, 人们已经开发出各种定性和定量的风险管理工具。如果要进一步了解有关的信息, 请参看有关文献。

在本书中, 主要讨论与通信网络有关的安全问题。网络安全事实上可以更广泛地定义为“通信安全”, 加密仅仅是通信安全的一个方面。其实网络安全涉及了非常广泛的技术领域, 而这些技术的广泛应用直到今天才成为可能。考虑到在现实中存在着各种强有力的密码分析方法, 人们不得不考虑采用复杂防护措施需要付出的各种代价。

1.3

网络安全策略

所谓安全策略, 是指在某个安全域内, 施加给所有与安全相关活动的一套规则。所谓安全域, 通常是指属于某个组织机构的一系列处理进程和通信资源。这些规则由该安全域中所设立的安全权威机构制定, 并由安全控制机构来描述、实施或实现。

安全策略是一个很宽泛的概念, 这一术语以许多不同的方式用于各种文献和标准。一些有关的分析表明, 安全策略有几个不同的等级。

(1) 安全策略目标: 是一个机构对于所保护的资源要达到的安全目标而进行的描述。

(2) 机构安全策略: 是一套法律、规则及实际操作方法, 用于规范一个机构如何管理、保护和分配资源, 以便达到安全策略所规定的安全目标。

(3) 系统安全策略: 描述如何将一个特定的信息系统付诸工程实现, 以支持此机构的安全策略要求。

在本书中, 术语“安全策略”通常是指系统级的安全策略。但是, 读者必须牢记, 它仅仅是广义安全策略概念的一个组成部分。

下面对影响网络系统及各组成部分所涉及的安全策略的某些主要方面进行讨论。

1.3.1 授权

授权 (Authorization) 是安全策略的一个基本组成部分。所谓授权, 是指主体 (用户、终端、程序等) 对客体 (数据、程序等) 的支配权利, 它等于规定了谁可以对什么做些什么 (Who may do what to what)。在机构安全策略等级上, 一些描述授权的例子如下:

(1) 文件 Project-X-Status 只能由 G.Smith 修改, 并由 G.Smith, P.Jones 及 Project-X 计划小组中的成员阅读。

(2) 一个人事记录只能由人事部门的职员进行添加和修改, 并且只能由人事部门的职员、部门经理及该记录所属的那个人阅读。

(3) 假设在多级安全系统中, 有一密级被定义为 “Confidential-secret-top”。只有所持许可证级别等于或高于此密级的人员才有权访问此密级的信息。

这些安全策略的描述也对各类防护措施提出了要求。例如, 采用人员安全措施来决定人员的许可证级别。在计算机和通信系统中, 主要安全需求可以由一种称为 “访问控制策略” 的系统安全策略反映出来。

1.3.2 访问控制策略

访问控制策略隶属于系统级安全策略, 它迫使计算机系统和网络自动地执行授权。以上有关授权描述的示例 (1)、(2) 和 (3) 分别对应于以下不同的访问控制策略:

(1) 基于身份的策略。该策略允许或拒绝对明确区分的个体或群体进行访问。

(2) 基于任务的策略。它是基于身份的策略的一种变形, 它给每一个个体分配任务, 并基于这些任务来使用授权规则。

(3) 多等级策略。它是基于信息敏感性的等级及工作人员许可等级而制定的一般规则的策略。

访问控制策略有时也被划分为强制性访问控制策略 (Mandatory Access Control Policies) 和自主性访问控制策略 (Discretionary Access Control Policies) 两类。强制性访问控制策略由安全域中的权威机构强制实施, 任何人都不能回避。强制性安全策略在军事和其他政府机密环境中最为常用, 上面提到的策略 (3) 就是一个例子。自主性访问控制策略为一些特定的用户提供了访问资源 (如信息) 的权限, 此后可以利用此权限控制这些用户对资源的进一步访问。上述策略 (1) 和策略 (2) 就是两个自主性访问控制策略的例子。在机密环境中, 自主性访问控制策略用于强化 “须知” (Need to know) 的最小权益策略 (Least Privilege Policy) 或最小泄漏策略 (Least Exposure Policy)。前者只授予主体为执行任务所必需的信息或处理能力, 而后者则按照规则向主体提供机密信息, 并且主体承担保护信息的责任。访问控制策略将在后面的章节中详细讨论。

1.3.3 责任

所有安全策略都有一个潜在的基本原则，那就是“责任”。在执行任务时，受到安全策略约束的任何个体需要对其行为负责。它与人员安全之间建立了非常重要的联系。某些网络安全防护措施，如对工作人员身份及采用这些身份从事相关的活动进行认证，都直接支持这一原则。

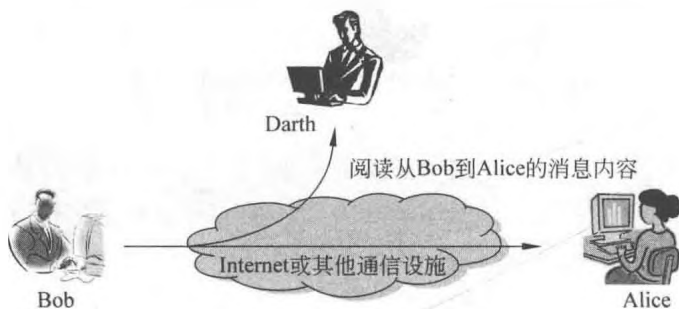
1.4 安全攻击的分类

X.800 和 RFC 2828 对安全攻击进行了分类。它们把攻击分成两类：被动攻击和主动攻击。被动攻击试图获得或利用系统的信息，但不会对系统的资源造成破坏。而主动攻击则不同，它试图破坏系统的资源，影响系统的正常工作。

1.4.1 被动攻击

被动攻击的特性是对所传输的信息进行窃听和监测。攻击者的目标是获得线路上所传输的信息。信息泄漏和流量分析就是两种被动攻击的例子。

第一种被动攻击是窃听攻击，如图 1-3 (a) 所示。电话、电子邮件和传输的文件中都可能含有敏感或秘密信息。攻击者通过窃听，可以截获这些敏感或秘密信息。我们要做的工作就是阻止攻击者获得这些信息。



(a) 窃听攻击



(b) 流量分析

图 1-3 被动攻击

第二种被动攻击是流量分析，如图 1-3（b）所示。假设已经采取了某种措施来隐藏消息内容或其他信息的流量，使攻击者即使捕获了消息也不能从中发现有价值的信息。加密是隐藏消息的常用方法。即使对信息进行了合理的加密保护，攻击者仍然可以通过流量分析获得这些消息的模式。攻击者可以确定通信主机的身份及其所处的位置，可以观察传输消息的频率和长度，然后根据所获得的这些信息推断本次通信的性质。

被动攻击由于不涉及对数据的更改，所以很难被察觉。通过采用加密措施，完全有可能阻止这种攻击。因此，处理被动攻击的重点是预防，而不是检测。

1.4.2 主动攻击

主动攻击是指恶意篡改数据流或伪造数据流等攻击行为，它分成 4 类：

- ① 伪装攻击（Impersonation Attack）；
- ② 重放攻击（Replay Attack）；
- ③ 消息篡改（Message Modification）；
- ④ 拒绝服务（Denial of Service）攻击。

伪装攻击是指某个实体假装成其他实体，对目标发起攻击，如图 1-4（a）所示。伪装攻击的例子有：攻击者捕获认证信息，然后将其重发，这样攻击者就有可能获得其他实体所拥有的访问权限。

重放攻击是指攻击者为了达到某种目的，将获得的信息再次发送，以在非授权的情况下进行传输，如图 1-4（b）所示。

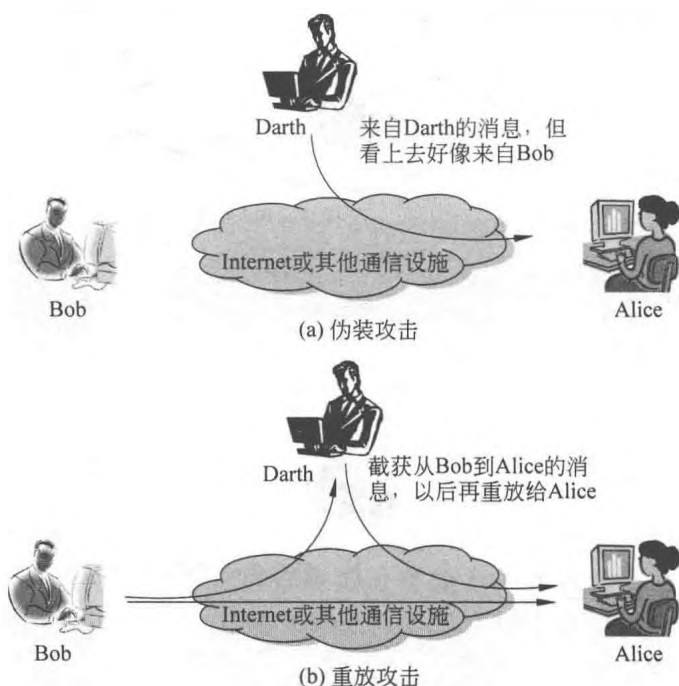


图 1-4 主动攻击

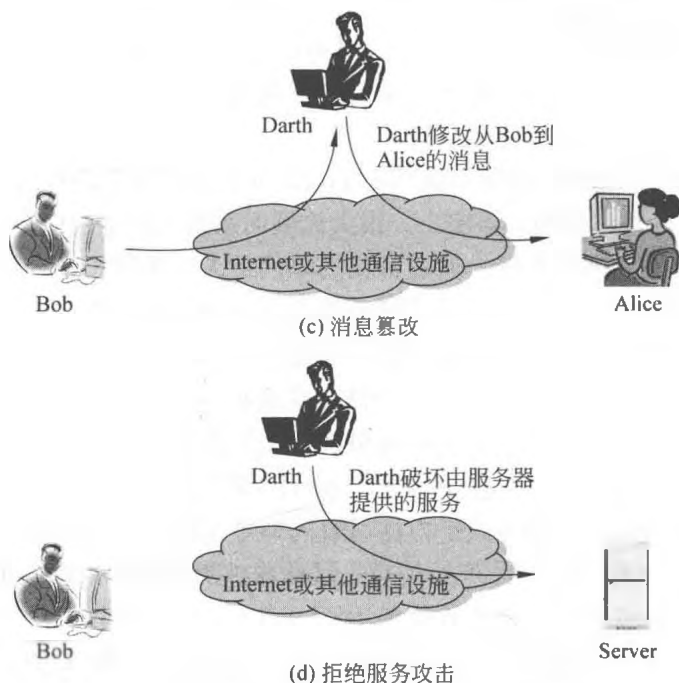


图 1-4 (续)

消息篡改是指攻击者对所获得的合法消息中的一部分进行修改或延迟消息的传输，以达到其非授权的目的，如图 1-4 (c) 所示。例如，攻击者将消息 “Allow John Smith to read confidential accounts” 修改为 “Allow Fred Brown to read confidential file accounts”。

拒绝服务攻击则是指阻止或禁止人们正常使用网络服务或管理通信设备，如图 1-4 (d) 所示。这种攻击可能目标非常明确。例如，某个实体可能会禁止所有发往某个目的地的消息。拒绝服务的另一种形式是破坏某个网络，使其瘫痪，或者使其过载以降低性能。

主动攻击与被动攻击相反。被动攻击虽然难以检测，但采取某些安全防护措施就可以有效阻止；主动攻击虽然易于检测，但却难以阻止。所以对付主动攻击的重点应当放在如何检测并发现它们上，并采取相应的应急响应措施，使系统从故障状态恢复到正常运行。由于检测主动攻击对于攻击者来说能起到威慑作用，所以在某种程度上可以阻止主动攻击。

1.5

网络攻击的常见形式

在前面已经讨论了网络中存在的各种威胁，这些威胁的直接表现形式就是黑客常采取的各种网络攻击方式。下面将对常见的网络攻击进行分类。通过分类，可以针对不同的攻击类型采取相应的安全防护措施。

1.5.1 口令窃取

进入一台计算机最容易的方法就是采用口令登录。只要在许可的登录次数范围内输入正确的口令，就可以成功地登录系统。

虽然利用系统缺陷破坏网络系统是可行的，但这不是最容易的办法。最容易的办法是通过窃取用户的口令进入系统。事实上，很大比例的系统入侵是由口令系统失效造成的。

口令系统失效的原因有多种，但最常见的原因是人们倾向于选择很糟糕的口令作为登录密码。反复研究的结果表明：口令猜测很容易成功。我们并不是说所有人都采用了很差的口令，但对于黑客来说，只要给他一次机会就可以得手。

口令猜测攻击有3种基本方式。第一种方式是利用已知或假定的口令尝试登录。虽然这种登录尝试需要反复进行十几次甚至更多，但往往会取得成功。一旦攻击者成功登录，网络的主要防线就会崩溃。很少有操作系统能够抵御从内部发起的攻击。

攻击者获得密码的第二种方式是根据窃取的口令文件进行猜测（如 UNIX 系统中的 `/etc/passwd` 文件）。这些口令文件有的是从已经被攻破的系统中窃取的，有的是从未被攻破的系统中获得的。由于用户习惯重复使用同一口令，当黑客得到这些文件后，就会尝试用其登录其他机器。这种攻击称为“字典攻击”，通常十分奏效。

第三种方法是窃听某次合法终端之间的会话，并记录所使用的口令。采用这种方式，不管用户的口令设计得有多好，其系统都会遭到破坏。

通过以上讨论可以得出结论：在选择好的口令方面，加强对用户的培训是非常重要的。大多数人习惯选择简单的口令。虽然人们也试图选用难以猜测的密码，但收效不大。据统计，攻击者如果掌握一本小字典，他就有 20% 的机会进入系统。况且现在可以获得的字典很多，大的可以达到几十兆字节。字典里几乎包括所有单词和短语，还有各种个人信息，如电话号码、地址、生日、作家名字等。

如果无法阻止选择低级的口令，那么对口令文件进行严格保护就变得非常关键。要做到这点，就必须进行以下操作：

- （1）对某些服务的安全属性进行认真配置，如 SUN 操作系统中的 NIS 服务。
- （2）对可以使用 `tftpd` 协议获得的文件加以限制。
- （3）避免将真正的 `/etc/passwd` 文件放在匿名 FTP 区。

某些 UNIX 系统提供了对合法用户的口令进行杂凑计算并将该杂凑值进行隐藏的功能。杂凑后的口令文件称为“影子”或“附属”口令文件。我们强烈建议充分利用系统的这一功能。除了 UNIX 系统之外，还有很多系统也具备对口令进行杂凑和隐藏的功能。

要彻底解决使用口令的弊端，就要完全放弃使用口令机制，转而使用基于令牌（Token-based）的机制。如果暂时还不能做到，起码要使用一次性口令方案，如 OTP（One-Time Password）。

1.5.2 欺骗攻击

黑客的另外一种攻击方式是采用欺骗的方式获取登录权限。泄密通常发生在打电话

和聊天的过程中。请看 Thompson 与网络管理员的一段谈话：

This is Thompson. Someone called me about a problem with the `ls` command. He'd like me to fix it.

Oh, OK. What should I do?

Just change the password on my login on your machine; it's been a while since I've used it.

No problem.

从上面的谈话可以看出，Thompson 欺骗网络管理员改变口令，使他能够成功登录到其计算机上。还有其他欺骗方式，如利用邮件欺骗。请看攻击者发出的这封邮件：

From: `smb@research.att.com`

TO: `admin@research.att.com`

Subject: Visitor

We have a visitor coming next week. Could you ask for your SA to add a Login for her? Here's her passwd line; use the same hashed password.

Pxf: 5bHD/k5k2mtTTs:2403:147:Pat:/home/pat:/bin/sh

注意，这封邮件明显带有欺骗行为。如果 Pat 是一个来访者，她不会将家里的机器口令拿到外面使用。因此，在没有搞清对方的真正意图之前，就不能随意采取行动。当你收到一个朋友的电子邮件，警告你“`sulfnbk.exe` 是一个病毒文件，必须删除。请转告你的朋友”时，这种电子邮件很可能就是一个骗局。如果你照此去做，你的系统就会中毒并遭到破坏。不幸的是，很多人都会上当，因为这个邮件毕竟是自己的朋友发送来的。

1.5.3 缺陷和后门攻击

网络蠕虫传播的方式之一是通过向 `finger` 守护程序 (Daemon) 发送新的代码实现的。显然，该守护程序并不希望收到这些代码，但在协议中没有限制接收这些代码的机制。守护程序的确可以发出一个 `gets` 呼叫，但并没有指定最大的缓冲区长度。蠕虫向“读”缓冲区内注入大量的数据，直到将 `gets` 堆栈中的返回地址覆盖。当守护程序中的子程序返回时，就会转而执行入侵者写入的代码。

缓冲器溢出攻击也称为“堆栈粉碎” (Stack Smashing) 攻击。这是攻击者常采用的一种扰乱程序的攻击方法。长期以来，人们试图通过改进设计来消除缓冲器溢出缺陷。有些计算机语言在设计时就尽可能不让攻击者做到这点。一些硬件系统也尽量不在堆栈上执行代码。此外，一些 C 编译器和库函数也使用了许多对付缓冲器溢出攻击的方法。

所谓缺陷 (Flaws)，就是指程序中的某些代码并不能满足特定的要求。尽管一些程序缺陷已经由厂家逐步解决，但是一些常见问题依然存在。最佳解决办法就是在编写软件时，力求做到准确、无误。然而，软件上的缺陷有时是很难避免的，这正是今天的软件中存在那么多缺陷的原因。

Morris 蠕虫及其许多现代变种给我们的教训极为深刻，其中最重要的一点是：缺陷导致的后果并不局限于产生不良的效果或造成某一特定服务的混乱，更可怕的是因为某

一部分代码的错误而导致整个系统的瘫痪。当然，没有人有意要编写带有缺陷的代码。只要采取相应的步骤，可以降低其发生的可能性。

第一，在编写网络服务器软件时，要充分考虑如何防止黑客的攻击行为。要检验所有输入数据的正确性。如果程序中使用了固定长度的缓冲器，要确保这些缓冲器不会产生溢出。如果使用了动态分配存储区的方法，要考虑内存或文件系统的占用情况，同时还要考虑到在系统恢复时也要占用内存和磁盘空间。

第二，必须对输入语法做出正确的定义。如果不能真正理解“正确”这两个字的含义，就不能做出正确性检查。如果不知道什么是合法的，就无法写出输入语法。有时，对于语法正确性的检查需要借助于某些编译工具。

第三，必须遵守“最小特权”原则。不要给网络守护程序授予任何超出其需要的权限。特别是在设置防火墙的访问控制规则时，轻易不要授予用户超级用户权限。例如，我们会给本地邮件转发系统的某些模块授予一定的特权，使其能将用户发送的信息复制到另外一个用户的邮箱里。而对于网关上的邮件服务器，通常不设置任何特权，它所做的事情仅局限于将邮件从一个网络端口复制到另一个网络端口。

如果进行恰当的设计，即使是那些好像需要授权的服务器，也不再需要授权。例如，UNIX 的 FTP 服务器，允许用户使用 `root` 权限登录，并能够绑定到 20 端口的数据通道上。对于 20 端口绑定是协议的要求，但可以采用一个更小的、更简单的和更明确的授权程序来做这件事。同样，登录问题也可以由一个前端软件来解决。该前端软件仅处理 `USER` 和 `PASS` 命令，放弃授权要求，并执行无特权程序。

最后需要指出：不要为了追求效率而牺牲对程序正确性的检查。如果仅仅为了节约几纳秒的执行时间而将程序设计得既复杂又别出心裁，并且又需要特权，那么你就错了。现在的计算机硬件速度越来越高，节约的这点时间毫无价值。一旦出现安全问题，在清除入侵上所花费的时间和付出的代价将是非常巨大的。

1.5.4 认证失效

许多攻击的成功都可归结于认证机制的失效。即使一个安全机制再好，也存在遭受攻击的可能性。例如，一个源地址有效性的验证机制，在某些应用场合（如有防火墙地址过滤时）能够发挥作用，但是黑客可以使用 `rpcbind` 重发某些请求。在这种情况下，最终的服务器就会被欺骗。对于这些服务器来说，这些消息看起来好像源于本地，但实际上来自其他地方。

如果源机器是不可信的，基于地址的认证也会失效。虽然人们可以采用口令机制来控制自己的计算机，但是口令失窃也是常见的事情。

某些认证机制失效是因为协议没有携带正确的信息。`TCP` 和 `IP` 都不能识别发送用户。`X11` 和 `rsh` 协议要么靠自己获得这些信息，要么就没有这些信息。如果它们能够得到信息，也必须以安全的方式通过网络传送这些信息。

即使对源主机或用户采用密码认证的方式，往往也不能奏效。如前所述，一个被破坏的主机不会进行安全加密。

窃听者可以很容易地从未加密的会话中获得明文的口令，有时也可能对某些一次口

令方案发起攻击。对于一个好的认证方案来说，下次登录必须具有唯一的有效口令。有时攻击者会将自己置于客户机和服务器中间，它仅仅转发服务器对客户机发出的“挑战”（challenge，实际上为一随机数），并从客户机获得一个正确的“响应”。此时，攻击者可以采用此“响应”信息登录到服务器上。有关此类攻击可参见相关文献。

通过修改认证方案消除其缺陷，完全可以挫败这种类型的攻击。基于“挑战/响应”（Challenge/Response）的认证机制完全可以通过精心设计的安全密码协议来消除这种攻击的威胁。

1.5.5 协议缺陷

前面讨论的是在系统完全正常工作情况下发生的攻击。但是，有些认证协议本身就存在安全缺陷，这些缺陷的存在会直接导致攻击的发生。

例如，攻击者可对 TCP 发起序列号攻击。由于在建立连接时所生成的初始序列号的随机性不够，攻击者很可能发起源地址欺骗攻击。为了做到公平，TCP 的序列号在设计时并没有考虑抵御恶意的攻击。其他基于序列号认证的协议也可能遭受同样的攻击。这样的协议有很多，如 DNS 和许多基于 RPC 的协议。

在密码学上，如何发现协议中存在的安全漏洞是非常重要的研究课题。有时错误是由协议的设计者无意造成的，但更多的安全漏洞是由不同的安全假设所引发的。对密码协议的安全性进行证明非常困难，人们正在加强这方面的研究工作。现在，各种学术刊物、安全公司网站和操作系统开发商经常公布一些新发现的安全漏洞，我们必须对此加以重视。

安全协议取决于安全的基础。例如，安全壳协议（Secure Shell，SSH）是一个安全的远程存取协议。SSH 协议具有这样一个特点：用户可以指定一个可信的公钥，并将其存储于 authorized keys 文件中。如果客户机知道相应的私钥，该用户不用输入口令就能登录。在 UNIX 系统中，该文件通常位于用户主目录下的.ssh 目录中。现在来考虑这样一种情况：有人使用 SSH 登录到某个加载了 NFS 主目录的主机上。在这种情况下，攻击者就可以欺骗 NFS 将一个伪造的 authorized keys 文件注入其主目录中。

802.11 无线数据通信标准中的 WEP 在设计上也存在缺陷。目前，针对 WEP 的攻击软件在网络上随处可见。这一切说明，真正的安全是很难做到的。工程师在设计密码协议时，应当多向密码学家咨询，而不是随意设计。信息安全对人的技术素质要求非常高，没有进行专业学习和受过专门培训的人员很难胜任此项工作。

1.5.6 信息泄漏

许多协议都会丢失一些信息，这就给那些想要使用该服务的攻击者提供了可乘之机。这些信息可能成为商业间谍窃取的目标，攻击者也可借助这些信息攻破系统。Finger 协议就是这样一个例子。这些信息除了可以用于口令猜测之外，还可以用来进行欺骗攻击。

有时，电话号码和办公室的房间号也可能很有用，可以根据电话号码本推理出该组织的结构。

在某些公司的网站上，往往提供了在线的电话号码查询。其实，公司的这些电话号码信息也应该是保密的。因为，当猎头们需要某些具有专业技能的人员时，他们可以根据这些信息打电话找到他们想要的专业人才。

另一个丰富的数据来源是 DNS。在这里，黑客可以获得从公司的组织结构到目标用户的非常有价值的信息。要控制数据的流出是非常困难的，唯一的办法是对外部可见的 DNS 加以限制，使其仅提供网关机器的地址列表。

精明的黑客当然深谙其理，他根本不需要你说出有哪些机器存在。他只需进行端口号和地址空间扫描，就可寻找感兴趣的服务和隐藏的主机。这里，对 DNS 进行保护的最佳防护措施是使用防火墙。如果黑客不能向某一主机发送数据包，他也就不能侵入该主机并获取有价值的信息。

1.5.7 指数攻击——病毒和蠕虫

指数攻击能够使用程序快速复制并传播攻击。当程序自行传播时，这些程序称为蠕虫（Worms）；当它们依附于其他程序传播时，这些程序就叫做病毒。它们传播的数学模型是相似的，因而两者之间的区别并不重要。这些程序的流行传播与生物感染病毒非常相似。

这些程序利用在很多系统或用户中普遍存在的缺陷和不良行为获得成功。它们可以在几个小时或几分钟之内扩散到全世界，从而使许多机构蒙受巨大损失。Melissa 蠕虫能够阻塞基于微软软件的电子邮件系统达 5 天之久。各种各样的蠕虫给 Internet 造成巨大的负担。这些程序本身更倾向于攻击随机的目标，而不是针对特定的个人或机构。但是，它们所携带的某些代码却可能对那些著名的政治目标或商业目标发起攻击。

有许多方法可以减少感染病毒的概率。最基本的方法是不使用流行的软件。如果采用自行编写的操作系统或应用程序，就不太可能受到感染。目前，针对微软的视窗操作系统的病毒有很多，但 Macintosh 和 UNIX 用户却很少受到病毒感染。现在这种情况正在发生变化，尤其是针对 Linux 的攻击越来越多。我们已发现 Linux 蠕虫和一些交叉平台的蠕虫能够通过几种平台进行传播，或者通过直接网络访问、网页浏览和电子邮件进行传播。

如果不与受感染的主机通信，就不会感染病毒。通过对网络访问和从外部获得的文件进行严格的控制，就会大大地降低遭受感染的风险。需要引起注意的是，有些病毒是经人工传播的。有人会将消息转发给他的所有朋友，并指示他们将此信息再转发给他们的所有朋友，以此类推。那些缺乏计算机知识的用户就会照此去做。这样，接收到这一消息的用户就会受到感染。在某些情况下，这些消息往往指示你删除某个关键的文件。如果真的照此去做，你的计算机就会受到损害。

对于已知的计算机病毒，采用流行的查杀病毒软件来清除非常有效。但是这些软件必须经常升级，因为病毒的制造者和杀毒软件厂商之间正进行着一场较量。现在，病毒隐藏的隐蔽性越来越高，使得杀毒软件不再局限于在可执行代码中寻找某些字符串。它们必须能够仿效这些代码并寻找滤过性病毒的行为特征。由于病毒越来越难以发现，病毒检测软件就不得不花更多的时间来检查每个文件，有时所花费的时间会很长。病毒的

制造者可能会巧妙地设计代码，使杀毒软件在一定的时间内不能识别出来。

1.5.8 拒绝服务攻击

在前面讨论的攻击方式中，大多数是基于协议的弱点、服务器软件的缺陷和人为因素而实施的。拒绝服务（Denial-of-Service, DoS）攻击则与之不同，它们仅仅是过度使用服务，使软件、硬件过度运行，使网络连接超出其容量。目的是造成自动关机或系统瘫痪，或者降低服务质量。这种攻击通常不会造成文件删除或数据丢失，因此是一种比较温和的攻击。

这类攻击往往比较明显，较容易发现。例如，关闭一个服务很容易被检测到。尽管攻击很容易暴露，但要找到攻击的源头却十分困难。这类攻击往往生成伪装的数据包，其中含有随机和无效的返回地址。

分布式拒绝服务（Distributed Denial-of-Service, DDoS）攻击使用很多 Internet 主机，同时向某个目标发起攻击。通常，参与攻击的主机却不明不白地成为攻击者的帮凶。这些主机可能已经被攻击者攻破，或者安装了恶意的代码。DDoS 攻击通常难以恢复，因为攻击有可能来自世界各地。

目前，由于黑客采用 DDoS 攻击成功地攻击了几个著名的网站，如 Yahoo、微软及 SCO 等，它已经引起全世界的广泛关注。DDoS 其实是 DoS 攻击的一种，不同的是它能够使用许多台计算机通过网络同时对某个网站发起攻击。它们的工作原理如下：

（1）黑客通过 Internet 将木马程序植入尽可能多的计算机上。这些计算机分布在全世界不同的区域。被植入的木马程序绑定在计算机的某个端口上，等待接受攻击命令。

（2）攻击者在 Internet 的某个地方安装一个主控程序，该主控程序中含有一个木马程序所处位置的列表。此后，主控程序等待黑客发出命令。

（3）攻击者等待时机，做好攻击命令前的准备。

（4）等攻击的时机一到，攻击者就会向主控程序发出一个消息，其中包括要攻击的目标地址。主控程序就会向每个植入木马程序的计算机发送攻击命令，这个命令中包含攻击目标的地址。

（5）这些木马程序立即向攻击目标发送大量的数据包。这些数据包的数量巨大，足以使其瘫痪。

从主控程序向下发出的攻击命令中通常使用伪装的源地址，有些则采用密码技术使其难以识别。从植入木马程序的计算机发出的数据包也使用了伪装的 IP 源地址，要想追查数据包的来源非常困难。此外，主控程序常常使用 ICMP 响应机制与攻击目标通信。许多防火墙都开放了 ICMP。

现在网络上流行许多 DDoS 攻击工具，还有它们的许多变种。其中之一是 Tribe Flood Network (TFN)。从许多网站上都可以获得其源代码。黑客可以选择使用各种 Flood 技术，如 UDP Flood, TCP SYN Flood, ICMP 响应 Flood, Smurf 攻击等。从主控程序返回的 ICMP 响应数据包会告诉木马程序采用哪一种 Flood 攻击方式。此外，还有其他 DDoS 工具，如 TFN2K（比 TFN 更先进的工具，可以攻击 Windows NT 和许多 UNIX 系统），Trinoo 和 Stacheldraht 等。最后一个工具十分先进，它具有加密连接和自动升级的特征。

现在一些新的工具越来越高明。Slapper 是一个攻击 Linux 系统的蠕虫，它可以在许多网络节点中间建立实体到实体（peer-to-peer）的网络，使主控程序的通信问题变得更加容易。还有一些工具则使用 IRC 信道作为控制通道。

对于拒绝服务攻击，没有什么灵丹妙药，只能采取一些措施减轻攻击的强度，但绝对不可能完全消除它们。遇到这种攻击时，可以采取以下 4 种措施：

- （1）寻找一种方法来过滤掉这些不良的数据包。
- （2）提高对接收数据进行处理的能力。
- （3）追查并关闭那些发动攻击的站点。
- （4）增加硬件设备或提高网络容量，以从容处理正常的负载和攻击数据流量。

当然，以上这些措施都不是完美的，只能与攻击者展开较量。到底谁能取得这场斗争的胜利，取决于对手能够走多远。

1.6

开放系统互连安全体系结构

研究信息系统安全体系结构的目的是，就是将普遍性的安全理论与实际信息系统相结合，形成满足信息系统安全需求的安全体系结构。应用安全体系结构的目的是，就是从管理上和技术上保证完整、准确地实现安全策略，满足安全需求。开放系统互连（Open System Interconnection, OSI）安全体系结构定义了必需的安全服务、安全机制和技术管理，以及它们在系统上的合理部署和关系配置。

由于基于计算机网络的信息系统以开放系统 Internet 为支撑平台，因此本节重点讨论开放系统互连安全体系结构。

OSI 安全体系结构的研究始于 1982 年，当时 ISO 基本参考模型刚刚确立。这项工作是由 ISO/IEC JTC1/SC21 完成的。国际标准化组织（ISO）于 1988 年发布了 ISO 7498-2 标准，作为 OSI 基本参考模型的新补充。1990 年，国际电信联盟（International Telecommunication Union, ITU）决定采用 ISO 7498-2 作为其 X.800 推荐标准。因此，X.800 和 ISO 7498-2 标准基本相同。

我国的国家标准《信息处理系统开放系统互连基本参考模型——第二部分：安全体系结构》（GB/T9387.2—1995）（等同于 ISO 7498-2）和《Internet 安全体系结构》（RFC 2401）中提到的安全体系结构是两个普遍适用的安全体系结构，用于保证在开放系统中进程与进程之间远距离安全交换信息。这些标准确立了与安全体系结构有关的一般要素，适用于开放系统之间需要通信保护的各种场合。这些标准在参考模型的框架内建立起一些指导原则与约束条件，从而提供了解决开放互连系统中安全问题的统一方法。

为了有效评估一个机构的安全需求，并对所使用的安全产品和安全策略进行评估和选择，安全管理员需要采用某种系统的方法来定义系统对安全的需求，并对这些需求进行描述。在集中处理环境下，要准确地做到这一点非常困难。随着局域网和广域网的使用，问题将变得更加复杂。

ITU-T 推荐方案 X.800（即 ISO 安全框架）定义了一种系统的评估和分析方法。对

于网络安全管理员来说，它提供了一种安全的组织方法。由于这个框架是作为国际标准开发的，所以被广泛使用。一些计算机和电信服务提供商已经在其产品和服务上开发出这些安全特性，使其产品和服务与安全机制的结构化定义紧密地联系在一起。

通过对 OSI 安全架构的讨论，可以对许多概念进行初步了解。下面重点讨论安全体系结构中所定义的安全服务和安全机制，以及两者之间存在的关系。

1.6.1 安全服务

X.800 对安全服务做出定义：为了保证系统或数据传输有足够的安全性，开放系统通信协议所提供的服务。RFC2828 也对安全服务做出了更加明确的定义：安全服务是一种由系统提供的对资源进行特殊保护的进程或通信服务。安全服务通过安全机制来实现安全策略。X.800 将这些服务分为 5 类共 14 个特定服务，如表 1-2 所示。这 5 类安全服务将在后面逐一进行讨论。

表 1-2 X.800 定义的 5 类安全服务

分 类	特定服务	内 容
认证（确保通信实体就是它所声称的实体）	同等实体认证	用于逻辑连接建立和数据传输阶段，为该连接的实体的身份提供可信性保障
	数据源点认证	在无连接传输时，保证收到的信息来源是所声称的来源
访问控制		防止对资源的非授权访问，包括防止以非授权的方式使用某一资源。这种访问控制要与不同的安全策略协调一致
数据保密性（保护数据，使之不被非授权地泄漏）	连接保密性	保护一次连接中所有的用户数据
	无连接保密性	保护单个数据单元里的所有用户数据
	选择域保密性	对一次连接或单个数据单元里选定的数据部分提供保密性保护
	流量保密性	保护那些可以通过观察流量而获得的信息
数据完整性（保证接收到的数据确实是授权实体发出的数据，即没有修改、插入、删除或重发）	具有恢复功能的连接完整性	提供一次连接中所有用户数据的完整性。检测整个数据序列内存在的修改、插入、删除或重发，且试图将其恢复
	无恢复功能的连接完整性	同具有恢复功能的连接完整性基本一致，但仅提供检测，无恢复功能
	选择域连接完整性	提供一次连接中传输的单个数据单元用户数据中选定部分的数据完整性，并判断选定域是否有修改、插入、删除或重发
	无连接完整性	为单个无连接数据单元提供完整性保护；判断选定域是否被修改
不可否认性（防止整个或部分通信过程中，任意一个通信实体进行否认的行为）	源点的不可否认性	证明消息由特定的一方发出
	信宿的不可否认性	证明消息被特定方收到

1. 认证

认证服务与保证通信的真实性有关。在单条消息下，如一条警告或报警信号认证服务是向接收方保证消息来自所声称的发送方。对于正在进行的交互，如终端和主机连接，就涉及两个方面的问题：首先，在连接的初始化阶段，认证服务保证两个实体是可信的，也就是说，每个实体都是它们所声称的实体；其次，认证服务必须保证该连接不受第三方的干扰，例如，第三方能够伪装成两个合法实体中的一方，进行非授权的传输或接收。

该标准还定义了如下两个特殊的认证服务：

（1）**同等实体认证**。用于在连接建立或数据传输阶段为连接中的同等实体提供身份确认。该服务提供这样的保证：一个实体不能实现伪装成另外一个实体或对上次连接的消息进行非授权重发的企图。

（2）**数据源认证**。为数据的来源提供确认，但对数据的复制或修改不提供保护。这种服务支持电子邮件这种类型的应用。在这种应用下，通信实体之间没有任何预先的交互。

2. 访问控制

在网络安全中，访问控制对那些通过通信连接对主机和应用的访问进行限制和控制。这种保护服务可应用于对资源的各种不同类型的访问。例如，这些访问包括使用通信资源、读/写或删除信息资源或处理信息资源的操作。为此，每个试图获得访问控制权限的实体必须在经过认证或识别之后，才能获取其相应的访问控制权限。

3. 数据保密性

保密性是防止传输的数据遭到诸如窃听、流量分析等被动攻击。对于数据传输，可以提供多层的保护。最常使用的方法是在某个时间段内对两个用户之间所传输的所有用户数据提供保护。例如，若两个系统之间建立了 TCP 连接，这种最通用的保护措施可以防止在 TCP 连接上传输用户数据的泄漏。此外，还可以采用一种更特殊的保密性服务，它可以对单条消息或对单条消息中的某个特定的区域提供保护。这种特殊的保护措施与普通的保护措施相比，所使用的场合更少，而且实现起来更复杂、更昂贵。

保密性的另外一个用途是防止流量分析。它可以使攻击者观察不到消息的信源和信宿、频率、长度或通信设施上的其他流量特征。

4. 数据完整性

与数据的保密性相比，数据完整性可以应用于消息流、单条消息或消息的选定部分。同样，最常用和直接的方法是对整个数据流提供保护。

面向连接的完整性服务保证收到的消息和发出的消息一致，不存在对消息进行复制、插入、修改、倒序、重发和破坏。因此，面向连接的完整性服务也能够解决消息流的修改和拒绝服务两个问题。另一方面，用于处理单条消息的无连接完整性服务通常仅防止对单条消息的修改。

另外，还可以区分有恢复功能的完整性服务和无恢复功能的完整性服务。因为数据完整性的破坏与主动攻击有关，所以重点在于检测而不是阻止攻击。如果检测到完整性遭到破坏，那么完整性服务能够报告这种破坏，并通过软件或人工干预的办法来恢复被破坏的部分。在后面可以看到，有些安全机制可以用来恢复数据的完整性。通常，自动

恢复机制是一种非常好的选择。

5. 不可否认性

不可否认性防止发送方或接收方否认传输或接收过某条消息。因此，当消息发出后，接收方能证明消息是由所声称的发送方发出的。同样，当消息接收后，发送方能证明消息确实是由所声称的接收方收到的。

6. 可用性服务

X.800 和 RFC2828 对可用性的定义是：根据系统的性能说明，能够按照系统所授权的实体的要求对系统或系统资源进行访问。也就是说，当用户请求服务时，如果系统设计时能够提供这些服务，则系统是可用的。许多攻击可能导致可用性的损失或降低。可以采取一些自动防御措施（如认证、加密等）来对付这些攻击。

X.800 将可用性看做是与其他安全服务相关的性质。但是，对可用性服务进行单独说明很有意义。可用性服务能够确保系统的可用性，能够对付由拒绝服务攻击引起的安全问题。由于它依赖于对系统资源的恰当管理和控制，因此它依赖于访问控制和其他安全服务。

1.6.2 安全机制

表 1-3 列出了 X.800 定义的安全机制。由表可知，这些安全机制可以分成两类：一类在特定的协议层实现，另一类不属于任何的协议层或安全服务。前一类被称做特定安全机制，共有 8 种；后一类被称为普遍安全机制，共有 5 种。

表 1-3 X.800 定义的安全机制

	分 类	内 容
特定安全机制(可以嵌入合适的协议层以提供一些 OSI 安全服务)	加密	运用数学算法将数据转换成不可知的形式。数据的变换和复原依赖于算法和一个或多个加密密钥
	数字签名	附加于数据单元之后的数据，它是对数据单元的密码变换，可使接收方证明数据的来源和完整性，并防止伪造
	访问控制	对资源实施访问控制的各种机制
	数据完整性	用于保证数据元或数据流的完整性的各种机制
	认证交换	通过信息交换来保证实体身份的各种机制
	流量填充	在数据流空隙中插入若干位以阻止流量分析
	路由控制	能够为某些数据动态地或预定地选取路由，确保只使用物理上安全的子网络、中继站或链路
	公证	利用可信的第三方来保证数据交换的某些性质
普遍安全机制(不局限于任何 OSI 安全服务或协议层的机制)	可信功能度	根据某些标准（如安全策略所设立的标准）被认为是正确的，就是可信的
	安全标志	资源（可能是数据元）的标志，以指明该资源的属性
	事件检测	检测与安全相关的事件
	安全审计跟踪	收集潜在可用于安全审计的数据，以便对系统的记录和活动进行独立地观察和检查
	安全恢复	处理来自诸如事件处置与管理功能等安全机制的请求，并采取恢复措施

1.6.3 安全服务与安全机制的关系

根据 X.800 的定义，安全服务与安全机制之间的关系如表 1-4 所示。该表详细说明了实现某种安全服务应该采用哪些安全机制。

表 1-4 安全服务与安全机制之间的关系

安全服务	加密	数字 签名	访问 控制	数据 完整性	认证 交换	流量 填充	路由 控制	公证
对等实体认证	Y	Y			Y			
数据源认证	Y	Y						
访问控制			Y					
保密性	Y						Y	
流量保密性	Y					Y	Y	
数据完整性	Y	Y		Y				
不可否认性		Y		Y				Y
可用性				Y	Y			

注：Y 表示该安全机制适合提供该种安全服务，空格表示该安全机制不适合提供该种安全服务。

表 1-5 安全服务与协议层之间的关系

安全服务	协议层						
	1	2	3	4	5	6	7
对等实体认证			Y	Y			Y
数据源点认证			Y	Y			Y
访问控制			Y	Y			Y
连接保密性	Y	Y	Y	Y		Y	Y
无连接保密性		Y	Y	Y		Y	Y
选择域保密性							Y
流量保密性						Y	Y
具有恢复功能的连接完整性	Y		Y				Y
不具有恢复功能的连接完整性				Y			Y
选择域有连接完整性			Y	Y			Y
无连接完整性							Y
选择域无连接完整性			Y	Y			Y
源点的不可否认							Y
信宿的不可否认							Y

注：Y 表示该服务应该在相应的层中提供，空格表示不提供。第 7 层必须提供所有的安全服务。

1.6.4 在 OSI 层中的服务配置

OSI 安全体系结构最重要的贡献是总结了各种安全服务在 OSI 参考模型的 7 层中的适当配置。安全服务与协议层之间的关系如表 1-5 所示。

1.7 网络安全模型

一个最广泛采用的网络安全模型如图 1-5 所示。通信一方要通过 Internet 将消息传送给另一方，那么通信双方（也称为交互的主体）必须通过执行严格的通信协议来共同完成消息交换。在 Internet 上，通信双方要建立一条从信源到信宿的路由，并共同使用通信协议（如 TCP/IP）来建立逻辑信息通道。

从图 1-5 中可以看出，一个网络安全模型通常由 6 个功能实体组成，它们分别是消息的发送方（信源）、消息的接收方（信宿）、安全变换、信息通道、可信的第三方和攻击者。

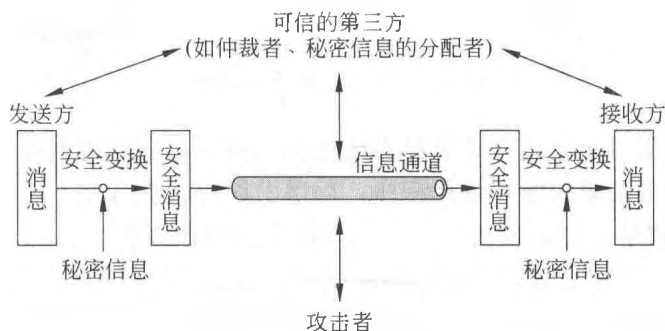


图 1-5 网络安全模型

在需要保护信息传输以防攻击者威胁消息的保密性、真实性和完整性时，就会涉及信息安全，任何用来保证信息安全的方法都包含如下两个方面：

（1）对被发送信息进行安全相关的变换。例如对消息加密，它打乱消息使得攻击者不能读懂消息，或者将基于消息的编码附于消息后，用于验证发送方的身份。

（2）使通信双方共享某些秘密信息，而这些消息不为攻击者所知。例如加密和解密密钥，在发送端加密算法采用加密密钥对所发送的消息加密，而在接收端解密算法采用解密密钥对收到的密文解密。

图 1-5 中的安全变换就是密码学课程中所学习的各种密码算法。安全信息通道的建立可以采用本书第 10 章讨论的密钥管理技术和第 14 章讨论的 VPN 技术实现。为了实现安全传输，需要有可信的第三方。例如，第三方负责将秘密信息分配给通信双方，而对攻击者保密，或者当通信双方就关于信息传输的真实性发生争执时，由第三方来仲裁。这部分内容就是本书第 9 章要讨论的 PKI/CA 技术。

网络安全模型说明，设计安全服务应包含以下 4 个方面内容：

- (1) 设计一个算法，它执行与安全相关的变换，该算法应是攻击者无法攻破的。
- (2) 产生算法所使用的秘密信息。
- (3) 设计分配和共享秘密信息的方法。
- (4) 指明通信双方使用的协议，该协议利用安全算法和秘密信息实现安全服务。

本书讨论的安全服务和安全机制基本上均遵循图 1-5 所示的网络安全模型。但是，还有一些安全应用方案不完全符合该模型，它们遵循图 1-6 所示的网络访问安全模型。该模型希望保护信息系统不受有害的访问。大多数读者都熟悉黑客引起的问题，黑客试图通过网络渗入到可访问的系统。有时他可能没有恶意，只是对闯入或进入计算机系统感到满足；或者入侵者可能是一个对公司不满的员工，想破坏公司的信息系统以发泄自己的不满；或者入侵者是一个罪犯，想利用计算机网络来获取非法的利益（如获取信用卡号或进行非法的资金转账）。

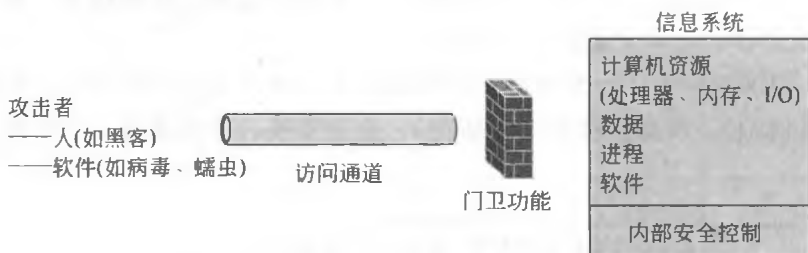


图 1-6 网络访问安全模型

另一种类型的有害访问是在计算机系统中加入程序，它利用系统的弱点来影响应用程序和实用程序，如编辑程序和编译程序。程序引起的威胁有如下两种：

- **信息访问威胁：**以非授权用户的名义截获或修改数据。
- **服务威胁：**利用计算机中的服务缺陷禁止合法用户使用这些服务。

病毒和蠕虫是两种软件攻击，它们隐藏在有用的软件中，并通过磁盘进入系统，也可以通过网络进入系统。网络安全更关心的是通过网络进入系统的攻击。

对付有害访问所需的安全机制可分为两大类，如图 1-6 所示。第一类称为门卫功能，它包含基于口令的登录过程，该过程只允许授权用户的访问。本书第 15 章的身份认证技术就属于此类安全机制。第二类称为内部安全监控程序，该程序负责检测和拒绝蠕虫、病毒及其他类似的攻击。一旦非法用户或软件获得了访问权，那么由各种内部控制程序组成的第二道防线就监视其活动、分析存储的信息，以便检测非法入侵者。本书第 12 章的防火墙技术和第 13 章的入侵检测技术均属于此类安全机制。

习 题

一、填空题

1. 信息安全的 3 个基本目标是_____、_____和_____。此外，还有一个不可忽视的目标是_____。
2. 网络中存在的 4 种基本安全威胁有_____、_____、_____、_____。

和_____。

3. 访问控制策略可以划分为_____和_____。

4. 安全性攻击可以划分为_____和_____。

5. X.800 定义的 5 类安全服务是_____, _____、_____, _____和_____。

6. X.800 定义的 8 种特定的安全机制是_____, _____、_____, _____、_____, _____、_____和_____。

7. X.800 定义的 5 种普遍的安全机制是_____, _____、_____, _____和_____。

二、思考题

1. 请简述通信安全、计算机安全和网络安全之间的联系与区别。

2. 基本的安全威胁有哪些？主要的渗入类型威胁是什么？主要的植入类型威胁是什么？请列出几种最主要的威胁。

3. 在安全领域中，除了采用密码技术的防护措施之外，还有哪些其他类型的防护措施？

4. 什么是安全策略？安全策略有几个不同的等级？

5. 什么是访问控制策略？什么是强制性访问控制策略？什么是自主性访问控制策略？

6. 主动攻击和被动攻击有何区别？请举例说明。

7. 网络攻击的常见形式有哪些？请逐一加以评述。

8. 请简述安全服务与安全机制之间的关系。

9. 请画出一个通用的网络安全模型，并说明每个功能实体的作用。

10. 什么是安全威胁、安全防护和风险？

11. 什么是授权？